

Financial Data Protection and Privacy Regulation 2024

FINANCIAL DATA PROTECTION AND PRIVACY REGULATION 2024

Issued by: Financial Regulatory Authority

Effective Date: January 1, 2025

Document Reference: FRA-DPP-2024-001

SECTION 1: SCOPE AND APPLICABILITY

1.1 This regulation applies to all financial institutions operating within the jurisdiction that collect, process, store, or transmit customer personal and financial data.

1.2 Institutions must designate a Chief Data Protection Officer (CDPO) within 90 days of this regulation taking effect.

1.3 All third-party vendors with access to customer data must be subject to equivalent data protection standards.

SECTION 2: DATA COLLECTION AND CONSENT

2.1 Financial institutions shall obtain explicit, informed consent from customers before collecting personal data beyond what is strictly necessary for the provision of contracted services.

2.2 Consent records must be maintained for a minimum of 7 years and must be producible on regulatory request within 48 hours.

2.3 Customers must be provided with clear opt-out mechanisms for non-essential data processing activities. Opt-out requests must be processed within 5 business days.

2.4 Institutions must provide customers with an annual data usage summary detailing all categories of data collected and their purposes.

SECTION 3: DATA SECURITY AND BREACH RESPONSE

3.1 All customer data at rest must be encrypted using AES-256 or equivalent approved encryption standards.

3.2 Customer data in transit must use TLS 1.3 or higher. Legacy protocols TLS 1.0 and 1.1 are prohibited.

3.3 Multi-factor authentication (MFA) is mandatory for all internal systems accessing customer personal data.

3.4 In the event of a data breach affecting 500 or more customers, the institution must notify the regulatory authority within 72 hours of discovery.

3.5 Breach notifications to affected customers must be issued within 30 days and must include a description of the data compromised, potential risks, and remediation steps taken.

3.6 Institutions must conduct penetration testing on all customer-facing systems at least annually.

SECTION 4: DATA RETENTION AND DELETION

4.1 Customer transaction data must be retained for a minimum of 5 years from the date of the last transaction.

4.2 Inactive customer records (no activity for 7+ years) must be reviewed for deletion or archival in compliance with applicable laws.

4.3 Upon customer request for data deletion, institutions must complete deletion within 30 days, except where retention is required by law.

4.4 Data deletion must be verified and documented through formal data destruction certificates.

SECTION 5: THIRD-PARTY AND VENDOR MANAGEMENT

5.1 All third-party vendors processing customer data must execute a Data Processing Agreement (DPA) with the institution prior to data access.

5.2 Vendor compliance with this regulation must be assessed annually through formal audits or certifications.

5.3 Institutions must maintain a complete and current inventory of all third-party vendors with access to customer data.

5.4 In the event of a vendor breach, the institution retains full accountability for regulatory compliance and must notify the authority as per Section 3.4.

SECTION 6: CUSTOMER RIGHTS

6.1 Customers have the right to access all personal data held by the institution. Requests must be fulfilled within 15 business days.

6.2 Customers may request correction of inaccurate personal data. Corrections must be processed within 10 business days.

6.3 Customers have the right to data portability. Institutions must provide data in a machine-readable format (CSV, JSON) within 20 business days of request.

6.4 Institutions must appoint a dedicated Customer Data Rights team or designated officer to handle all data rights requests.

SECTION 7: GOVERNANCE AND ACCOUNTABILITY

7.1 The board of directors must receive a quarterly data protection compliance report.

7.2 Institutions must maintain an internal data protection register documenting all processing activities, lawful bases, and retention schedules.

7.3 A Data Protection Impact Assessment (DPIA) must be conducted for any new system or process involving large-scale processing of customer personal data.

7.4 Staff with access to customer data must complete annual data protection training. Completion records must be maintained for 3 years.

PENALTIES

Non-compliance with this regulation may result in fines of up to 4% of annual global turnover or \$10 million, whichever is greater, per violation.